Threat evolution in Q4 2016

GROUP IB
GLOBAL CYBER SECURITY COMPANY

Table of contents

Introduction 3

Executive Summary: Threats to the Government sector 6

Forecasts for Q1 2017 7

Threats to the Financial Sector, Global 8

Targeted attacks 8

Banking threats for PC and Android 12

Attacks on ATM and POS terminals 26

Data leakage 27

Threats to the Financial Sector in Russia 28

Targeted attacks 28

Banking Trojans for PC and Android 29

Attacks on ATMs 32

Data leakage 32

Threats to the Government sector 33

APT 33

Hacktivism 34

Data leakage 36

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on the USA, Europe, Russia and Australia. This document also provides a comprehensive description of threats to governments, including hacktivists' attacks, targeted attacks supported by government and significant data leaks.

Researchers have observed that malware used to target victims in Russia is often then 'exported' to other countries, that is why we believe it is essential to inform our international clients about Russian threats along with those targeting them directly.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring the most secretive underground hacker forums and accumulating information on new trends, threats and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages and announcements on the dark web as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive Summary: Threats to the Financial Sector, Global

Targeted attacks

- The Cobalt group continued attacking banks worldwide. In September-October the gang attacked banks in Armenia, Azerbaijan, Belorussia, Hungary, Russia, and in December it infected financial institutions in Russia, Bulgaria, Georgia, Turkey, and Tunisia. Besides, Group-IB specialists confirmed that the July 2016 ATM attacks against Taiwan were conducted by Cobalt group (or using their malware). We named this malware «ATMSpitter».
- Specialists detected a new group performing targeted attacks that was dubbed MoneyTaker. At the time of the report, Group-IB specialists discovered only incidents related to a Russian banking application – Automated Working Station of the Central Bank Client (AWS CBC). However, we expect that the criminals will start targeting foreign financial institutions.
- Brokerage systems throughout the world are continuously under the threat of targeted attacks.
- In Q4 2016, developers added an exploit CVE-2016-0189 to the OffensiveWare exploit pack. Also, a new local privilege escalation exploit for CVE-2016-7255 was detected to be available for purchase on underground forums. These exploit packs are currently used by cybercriminals to perform targeted attacks.

Banking threats for PC and Android

Trojans for Android were used to steal money from the accounts of individuals, while PC Trojans were used both for attacks on individuals and companies. All malicious programs targeting clients of foreign banks, which are outlined in this report section, are not used on the territory of CIS countries.

Trojans for Android:

- Marcher and Marcher 2 (Alien bot) were used to attack banks in Australia, Germany, Italy, the Netherlands, Sweden, Turkey, and the UK.
- GM Bot was used in attacks against Australian banks; a new version of the Trojan appeared.
- Tiny.z (aka Catelites Android Bot) was used to attack banks in Europe, the USA, Kazakhstan, Russia and other countries.
- Agent.BID was used to attack banks in some countries.

Trojans for PC

- During the reporting period, Group-IB specialists discovered attacks on banks in Europe, the USA, Canada, and Australia using the following banking Trojans: Qadars, Vawtrak, Dridex, Atmos, ISFB (Gozi), Zeus, KINS, Tinba, Qbot, Gootkit, Kronos, Ramnit.
- Specialists determined that Trickbot had configuration file settings to attack banks in Australia, Canada, the UK, and Germany.
- The banking Trojan dubbed "Panda Banker" was detected to be sold on a major underground forum via private messages without a separate topic on the Trojan sales;
- Snatch malware was detected available for purchase. The program has powerful functionality as a loader and credential grabber; that said, its price is relatively low.
- A new loader named Quant loader appeared;

- Criminals started selling a Trojan named Hidden VNC33, which is designed to remotely control Windows-based computers.

Attacks on ATM and POS terminals

The major threats for ATMs are attacks performed by the Cobalt group, a new malware named Alice, and Blackbox devices.

To attack POS terminals criminals use specialized Trojans, which are expected to be actively employed for thefts during the winter holidays.

Data leakage

In Q4 2016 the following major data leaks were detected:

- Tesco Bank
- GeekedIn
- Ethereum Project
- Yahoo!
- The file hosting service MEGA
- Resources of the company Friend Finder Networks

Executive Summary: Threats to Financial Sector in Russia

Targeted attacks

Hackers conduct targeted attacks on banks in order to steal money or get access to payment systems, POS terminals and ATMs. In Q4 2016 activity of 2 criminal groups performing attacks in Russia was recorded: Cobalt and MoneyTaker.

Banking Trojans for PC and Android

During the reporting period, Group-IB specialists detected attacks on Russian banks using specific Trojans. The vast majority of Trojans for PC were used to deplete accounts of businesses, while mobile Trojans were used to steal money from the accounts of individuals. In Q4 2016, Group-IB specialists observed activity of the following banking Trojans:

- Trojans for PC: ProxyAdder, RTM, Jupiter (aka Bolek); the Buhtrap Trojan returned – new incidents using this tool were detected.
  Group-IB specialists detected new version of Buhtrap malware with module for ATS (automatic transfer system) for «1C» system.
  It's worth noting that the Proxy group started using the Buhtrap malware and programs of the Ransomware type along with their own program ProxyAdder.
  In Q4 Group-IB systems did not detect the Ranbyus Trojan, because the group using this malware stopped their activity again.
- Mobile Trojans: Agent.BID, Tiny.z, Asacub, Gugi (Limebot), Honli, Opfake.
- In Q4 2016 activity of Agent.sx, FakeInst.fb Trojans decreased compared to the previous quarter. Also, members of the group that used Cron malware were arrested. They attacked only Russian banks, however, they are believed to have planned attacks on French banks just before the arrest.

Attacks on ATMs

The Cobalt group continued targeting ATMs. Also, activity of a criminal group using a tool designed for stealing money from ATMs named Blackbox was detected in Russia.

Data leakage

- During the reporting period Group-IB specialists detected activity from eight groups of malicious insiders. They continued creating services designed to sell confidential bank data and promoted them on underground platforms.

Executive Summary: Threats to the Government sector

Targeted attacks

Governments are always going to be under the threat of cyber espionage and in some cases suffer attacks on critical infrastructure. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies. In Q4 2016 the following active APT campaigns were detected:

- Cozy Bear (APT29, CozyDuke, The Dukes)
- The Shadow Brokers
- KeyBoy
- Fancy Bear (APT28, Sofacy, Pawn storm, Sednit, Strontium Tsar Team)
- Moonlight
- Blackgear

Hacktivism

In Q4 2016, hacktivists conducted over 2,200 attacks on more than 2,600 online resources. Over 1,100 attacks detected were “page replacement” (Defacement) and 1,067 attacks were DDoS attacks (Denial of Service) targeting government, financial, commercial, non-governmental and non-profit organizations. Government websites suffered hacker attacks include those of Israel, the USA, Turkey, Russia, Peru, the UK, India, Germany, Brazil and Venezuela.

Data leakage

During the reporting period, analysts detected the following leaks of government databases:

- On October 23 the website of the Russian Ministry of Foreign Affairs was hacked and defaced.
- In early November Donald Trump’s presidential campaign website was hacked by exploiting a vulnerability.

Forecasts for Q1 2017

Based on the threats detected, we can forecast the following future incidents in Europe, the USA, Australia, Canada:

1) Group-IB specialists expect new attacks on ATMs and SWIFT performed by the Cobalt group. MoneyTaker is expected to be active and could start attacking banks in Europe, the US, and Australia.
   Cobalt and MoneyTaker have already accessed several bank networks. Based on our experience, we expect a notable spike of fraudulent activity in late December-early January. Attackers intentionally choose days when employees go on vacation.
2) GMBot, Marcher, and Marcher 2 (Alien bot) will remain the most dangerous Trojans for Android; Group-IB specialists expect an increase in the number of groups using these tools;
3) The amount of criminal groups using an Android Trojan named Tiny.z (Catellites Android Bot) will increase;
4) Trickbot banking Trojan will stop being tested, and will be actively used to attack banks in Australia and Canada.
5) The following banking Trojans for Windows will be active: Qadars, Gootkit, Tinba, Zeus, KINS, Vawtrak, Gozi, Atmos, Ramnit.

Based on the threats detected, we can forecast the following future incidents in Russia and the CIS:

1) The Cobalt criminal group will attempt to access bank corporate networks and steal money from ATMs.
   MoneyTaker will continue attacks via banking systems and will likely use new tactics.
   It's worth noting that these groups can be active in late December-early January, when many bank employees are on their winter vacation.
2) RTM and Buhtrap Trojans will be the most dangerous Trojans in Russia;
3) Agent.BID and Limebot will be the major threats to mobile banking;
4) Criminal groups using an Android Trojan named Tiny.z (Catellites Android Bot) will attack both foreign and Russian banks;
5) We predict attacks from the Proxy hacker group that may result in thefts of large amounts of money from clients of Russian banks;
6) In early 2017 the amount of attacks using Android Trojans and thefts via SMS will decrease.

Threats to the Financial Sector, Global

Targeted attacks

APT name	Regions attacked	Related notifications	Operation start
Targeted attacks on banks using the Cobalt Strike software	Banks worldwide	CP-1438-4 CP-1438-5 CP-1438-6 CP-1438-7 CP-1438-8 CP-1508	June 2016

In Q4 2016 new attacks from the Cobalt group and related indicators of compromise were detected. Targeted attacks were performed acting as Diebold and Wincor Nixdorf companies (ATM manufacturers), and Center of Financial Technologies, a provider of solutions for the financial market of Russia and the CIS. Emails contained a malicious RTF document with an exploit for CVE-2015-1641.

Group-IB specialists also determined that the group modified the malware to complicate its detection:

- RTF objects were modified to purportedly avoid detection by YARA rules. They were adjusted in the manner that could not affect their workability, for example, developers added symbols to the names of objects.
- Loaders now have the PE structure corrupted on purpose, which significantly complicates file analysis. The current payload does not contain a string beacon.dll as the “original file name” in the PE header.

In September-October 2016 the group attacked banks in Armenia, Azerbaijan, Belorussia, Hungary, Russia, and in December attacks on banks in Russia, Bulgaria, Georgia, Turkey, and Tunisia were detected.

Besides, in December 2016 Group-IB specialists confirmed that the July 2016 ATM attacks against Taiwan were conducted by Cobalt group (or using their malware). We named this malware «ATMSpitter».

Regions attacked	Related notifications	Operation start	Regions attacked
MoneyTaker	Russia	CP-1500	August 2016

In late November a new criminal group using a new type of targeted attack was identified. Hackers used the Moneytaker malware to furtively replace data in payment orders in a free application called Automated Working Station of the Central Bank Client (AWS CBC). Moneytaker has several modules: the core module, a module for automated data replacement, a module for hiding the malware, and a module for operation with temporary files. The attackers replace legitimate payment orders in AWS CBC with their own so that money would be sent to accounts they control instead of the legitimate recipient. The legitimate user receives a system response as if payment details were not changed and does not notice manipulations, which provides the criminal with additional time.

In addition to the above-mentioned malware, the criminals use various remote control tools, Mimikatz, Metasploit modules, as well as data grabbers and a keylogger.

At the time of this report, attacks have targeted only Russian banks. However, Group-IB specialists note that the criminals have advanced technical skills to modify their malware for attacks on other systems and are expected to refocus on foreign banks in the future.

Regions attacked	Related notifications	Operation start	Regions attacked
Targeted attacks on trading and brokerage systems	Global	CP-1481	2015

Trading and brokerage systems are continuously under threat from targeted cyber-attacks. In October 2016, the Securities and Futures Commission (SFC), which is an independent statutory body set up to regulate Hong Kong's securities and futures markets, published a circular developed to “notify the industry of cybersecurity review on internet/mobile trading systems”. According to this document, for 12 months ending September 30th 2016, there were 16 reported hacking incidents which involved 7 securities brokers and total unauthorized trades in excess of $100 million. These hacking incidents are still under police investigation.

It’s worth reiterating, that Group-IB warned and informed Bot-Trek Intelligence customers when attacks on brokerage systems started.

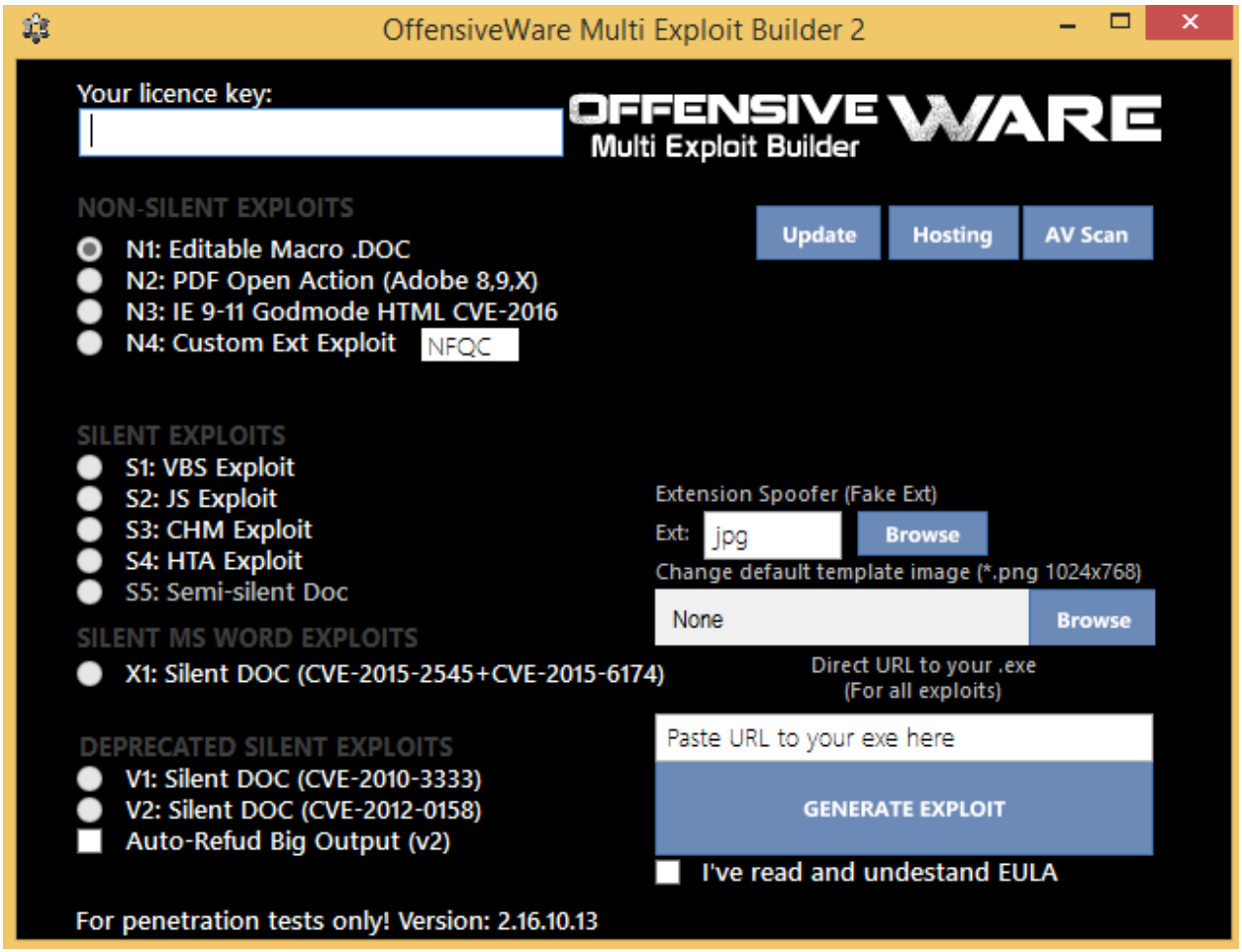
In Russia there were at least 3 criminal groups that were able to attack brokerage systems: Anunak, Corkow, Lurk. Specialists detected successful attacks using Corkow, while Anunak and Lurk were discovered to have the functionality to perform attacks of this type.

One of the major successful attacks occurred in February 2015, when hackers gained unsanctioned access to trading system terminals using the Corkow Trojan and made 7 trades for the purchase and sale of more than $500 million USD.

Exploits used to perform targeted attacks	Regions attacked	Related notifications
OffensiveWare (aka Ancalog Multi Exploit Builder) Microsoft Word Intruder Exploits of the Equation group Exploit for CVE-2016-0189	Global	CP-1482 CP-1496

To perform targeted attacks, in particular, to create malicious email attachments, the criminals use the following exploit packs: OffensiveWare, Microsoft Word Intruder and others.

In Q4 2016 developers added an exploit for CVE-2016-0189 leveraging a vulnerability in Microsoft JScript 5.8 and VBScript 5.7 and 5.8, which are used in Internet Explorer versions 9-11 and other software. The exploit allows remote attackers to execute arbitrary code or cause a denial of service (memory corruption).



Interface of OffensiveWare Multi Exploit Builder

An exploit for local privilege escalation (LPE) for the CVE-2016-7255 vulnerability available for purchase was detected on underground resources. The vulnerability that exists in the win32k.sys kernel module and can be found in all supported versions of Windows, was originally disclosed by Google's Threat Analysis Group on October 31st, 2016. This bug leading to LPE is especially useful for escaping browser sandboxes. Microsoft released a patch for this vulnerability on November 8. The malware developer says that the exploit operates on Windows versions starting from XP and supports x86/x64 architectures. It is able to bypass the following Windows protection mechanisms:

- SMEP
- Kernel DEP
- KASLR
- Integrity Level (to elevate out of Low)
- NULL Dereference Protection
- UAC

Group-IB specialists believe that attackers will leverage privilege escalation to conduct targeted attacks, in particular to improve effectiveness of Mimikatz that requires local administrator privileges.

The developer also says that this exploit cannot be detected by the following systems for proactive cyber defence:

- KIS 2015
- Avast IS 2015
- ESET Smart Security 8

The exploit is a shellcode that can be built in any malware. It's worth noting that the author is a well-known developer of exploits and droppers.

In addition to that, a group named Shadow Brokers that had breached databases of Equation Group and auctioned the exploits and the tools they found demanding an enormous price of 1 million Bitcoins for the archive. The group later changed their pricing policy and sales methods by selling off their alleged cracked tools piecemeal at Bitcoin prices ranging from 1 BTC to 100 BTC. The entire archive is for sale for 1,000 BTC, which is a thousand times less than the original price. This tool will likely be used to conduct targeted attacks by other criminal groups.

https://bit.no.com:43110/theshadowbrokers.bit/

THESHADOWBROKERS.BIT

LISTOFWARES MESSAGES CONTACT

THESHADOWBROKERS ON ZERONET

YOU LIKE. YOU EMAIL. YOU BUY.

Message#6

Download Screenshots (sig)

Name	Type	BTC
auction_file	everything	1,000.0
bs	unknown	10.0
catflap	unknown	10.0
charms	implant	100.0
common	unknown	10.0
curses	implant	100.0
dampcrowd	unknown	10.0
dewdrop	implant	100.0
dubmoat	trojan	10.0
earlyshovel	exploit	10.0
ebb	exploit	10.0
eggbasket	exploit	10.0
eh	unknown	10.0
elatedmonkey	exploit	10.0
eldestmyriad	exploit	10.0
electricslide	exploit	10.0
eleganteagle	exploit	10.0
elgingamble	exploit	10.0
endlessdonut	exploit	10.0
enemyrun	implant	100.0
englandboggy	exploit	10.0
envisioncollision	unknown	10.0
envoytomato	unknown	10.0
epichero	exploit	10.0
es	exploit	10.0
esna	exploit	10.0
estopmoonlit	exploit	10.0
evolvingstrategy	unknown	10.0
ewok	unknown	10.0
exactchange	exploit	10.0
expoxyresin	unknown	10.0
exze	unknown	10.0
forkpty	tool	1.0
ghost	unknown	10.0
gr	unknown	10.0
itime	unknown	10.0
jackladder+incision	implant	100.0
km	exploit	10.0
magicjack	implant	10.0
nopen	RAT	100.0
orleanstride	implant	100.0
pclean	tool	1.0
pork	implant	10.0
seconddate	implant	100.0
shentysdelight	tool	10.0
sift	implant	10.0
skimcountry	implant	100.0
slyheretic_checker	tool	1.0
stoicsurgoen_ctrl	tool	1.0
strifeworld	implant	10.0
suaveeyeful	unknown	10.0
suctionchar	implant	100.0
toast	tool	1.0
violetspirit	unknown	10.0
watcher	tool	1.0
yellowspirit	unknown	10.0

Tools leaked from the Equation group databases that are offered for purchase by Shadow Brokers

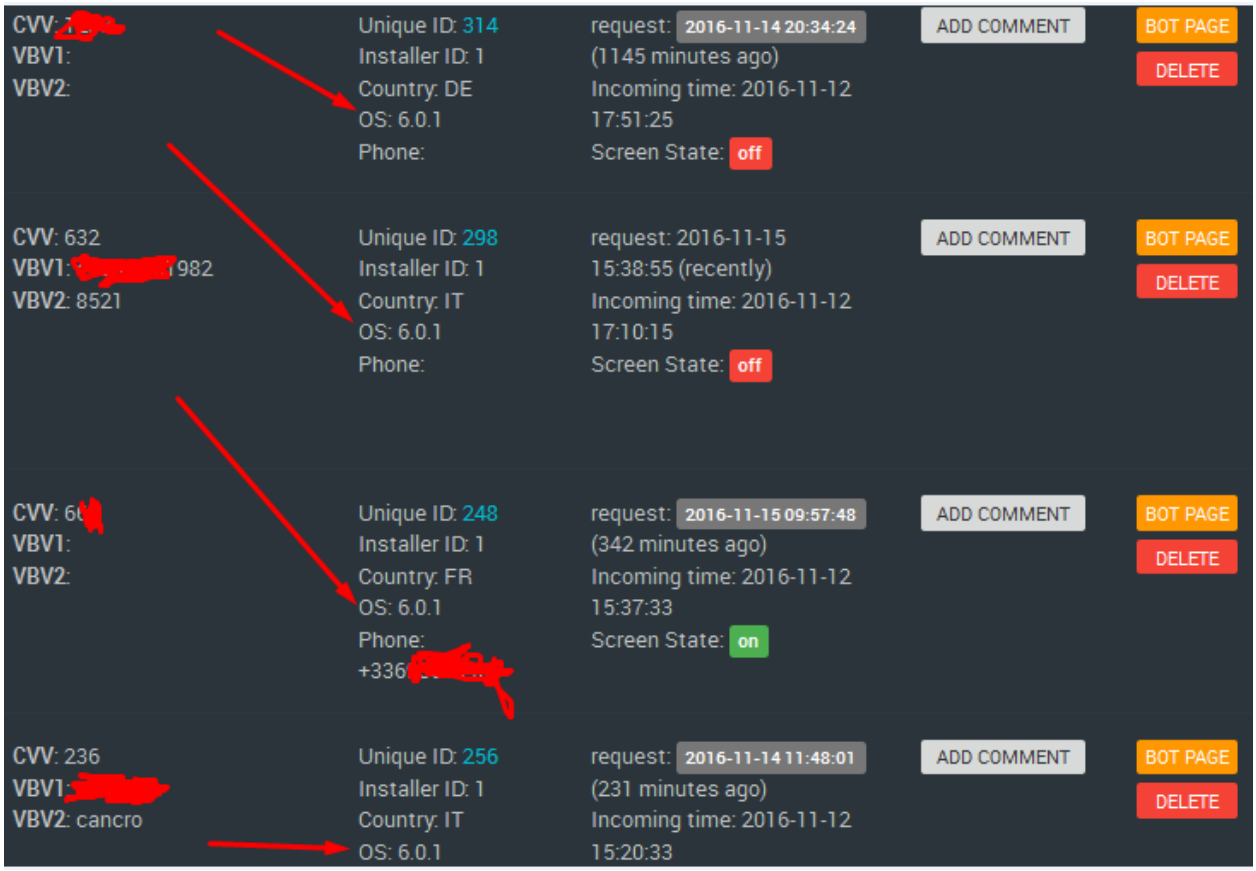
Banking threats for PC and Android

Malware name	Regions attacked	Detection	Notification
GM bot (aka Mazar)	Global	October 2014	CP-1487

In October an announcement about an updated version of the Mazar Trojan (aka GM Bot) – version 3 – was published on an underground forum. The Trojan offered for purchase is able to intercept SMS confirmations, and enables the attacker to compromise bank card data and online banking accounts.

The key difference of Mazar v.3.0 from previous versions is capability to bypass Android 6 Marshmallow protection. The source code was purportedly borrowed from another developer Jared Rummler who published it on GitHub. Mazar v.3.0 has access to the system file within the /proc/ directory, and identifies applications that are displayed in the foreground. Due to this function, Mazar can select and display any fake interface on top of the real application.

The control panel of Mazar v.3.0 is written in PHP (the previous control panel was written in Python/Django).



Mazar 3 control panel

Also, during the reporting period, Group-IB specialists detected a GM Bot sample attacking the following banks in Australia:

Mebank
SuncorpBank
ANZ

Bendigobank
Bank of Melnourne
Banksa
Stgeorge bank
NAB
Westpac
Commbank

Malware name	Regions attacked	Detection	Notification
Marcher Marcher 2	Global	2013	CG-1497

Marcher is an Android banking Trojan. Also, there is Marcher 2 (aka Alien bot) developed based on the Marcher source code. During the reporting period, a criminal group dubbed busy897987989879 using both Marcher versions was detected. The hackers primarily attack banks in Australia, Germany, Italy, the Netherlands, Sweden, and Turkey. Group-IB specialists determined that members of this group were likely Russian-speaking hackers.

The busy897987989879 group uses Marcher (ver.1) to attack the following banks:

Commonwealth Bank
ANZ Bank
Standard Chartered Bank PLC
TURKIYE IS BANKASI A.S.
Credit Agricole
DBS Bank
Rakuten Inc.
Swedbank
POSTE ITALIANE S.P.A.
BENDIGO AND ADELAIDE BANK, LTD.
WESTPAC
AUSTRALIA POST
ST. GEORGE BANK, LTD.
NATIONAL AUSTRALIA BANK, LTD.
NEWCASTLE PERMANENT BUILDING SOCIETY, LTD.
SUNCORP-METWAY, LTD.
CUSCAL, LTD.
HERITAGE BUILDING SOCIETY, LTD.
BANK OF QUEENSLAND, LTD.
CREDIT UNION SERVICES CORPORATION (AUSTRALIA) LIMITED
PEOPLES CHOICE CREDIT UNION
BANKWEST
VICTORIA TEACHERS CREDIT UNION
WOOLWORTHS MONEY
INDUE, LTD.
GE CAPITAL FINANCE AUSTRALIA
BankSA
IMB Bank
NAB
CITIGROUP PTY, LTD.

Marcher 2.0 (Alien bot) used by the busy897987989879 group contains injects for the following banking applications:

me.doubledutch.rbccapitalmarkets
com.wf.wellsfargomobile
com.usb.cps.axol.usbc
com.usaa.mobile.android.usaa
com.unionbank.ecommerce.mobile.android
com.transferwise.android
com.tdbank
com.td
com.suntrust.mobilebanking
com.pnc.ecommerce.mobile
com.paypal.android.p2pmobile
com.paybybank.westernunion
com.moneybookers.skrillpayments
com.jpm.sig.android
com.infonow.bofa
com.firstpremier.mypremiercreditcard
com.fi9228.godough
com.discoverfinancial.mobile

com.creditkarma.mobile
com.coinbase.android
com.clairmail.fth
com.citi.citimobile
com.cibc.android.mobi
com.chase.sig.android
com.americanexpress.android.acctsvcs.us
ca.bnc.android
com.commbank.netbank
org.westpac.bank
org.stgeorge.bank
au.com.nab.mobile
au.com.ingdirect.android
au.com.bankwest.mobile
org.banksa.bank
at.bawag.mbanking
at.easybank.mbanking
at.spardat.netbanking
at.volksbank.volksbankmobile
com.bankaustria.android.olb
com.isis_papyrus.raiffeisen_pay_eyewdg
com.db.mm.deutschebank
com.ing.diba.mbbr2
com.starfinanz.mobile.android.dkbpushtan
com.starfinanz.smob.android.sbanking
com.starfinanz.smob.android.sfinanzstatus
de.adesso.mobile.android.gad
de.comdirect.android
de.commerzbanking.mobil
de.consorsbank
de.dkb.portalapp
de.fiducia.smartphone.android.banking.vr
de.ing_diba.kontostand
de.postbank.finanzassistent
mobile.santander.de
com.arkea.android.application.cmb
com.arkea.android.application.cmso2
com.boursorama.android.clients
com.cacf.MonCACF
com.caisseepargne.android.mobilebanking
com.cic_prod.bad
com.cm_prod.bad
com.fullsix.android.labanquepostale.accountacc
ess
com.groupama.toujoursla
com.IngDirectAndroid
com.lbp.peps
com.macif.mobile.application.android
com.ocito.cdn.activity.creditdunord
fr.axa.monaxa
fr.banquepopulaire.cyberplus
fr.banquepopulaire.cyberplus.pro
fr.creditagricole.androidapp
fr.lcl.android.customerarea
fr.lemonway.groupama
mobi.societegenerale.mobile.lappli
net.bnpparibas.mescomptes
com.comarch.mobile
com.getingroup.mobilebanking
com.konylabs.cbplpat
eu.eleader.mobilebanking.pekao
eu.eleader.mobilebanking.raiffeisen
pl.bzwbk.bzwbk24
pl.bzwbk.mobile.tab.bzwbk24
pl.eurobank
pl.ing.ingmobile
pl.mbank
pl.pkobp.iko
wit.android.bcpBankingApp.millenniumPL
com.akbank.android.apps.akbank_direkt
com.finansbank.mobile.cepsube
com.garanti.cepsubesi
com.pozitron.iscep
com.tmobtech.halkbank
com.vakifbank.mobile
com.ykb.android
com.ziraat.ziraatmobil

However, Group-IB researchers also detected other gangs using Marcher and Marcher 2. In addition to the above-mentioned banks, they target the following banks:

Marcher:

Barclays
RBS
Natwest
Commerzbank
ING bank
Starfinanz
Santander
Deutsche Kreditbank Aktiengesellschaft (DKB)

HSBC
Spardat
Postbank
Lloyds
Raiffeisen
Fiducia
Volksbank
Deutschebank
Citibank CZ
Consorsbank
Halifax
Bawag
Adesso

Marcher 2:

Sparkasse
Halifax
ING Bank
Transferwise.Android
Tsb.co.uk
Lloyds
Isbank
Yapikredi

Malware name	Regions attacked	Detection	Notification
Tiny.z (Catelites Android Bot)	All countries	Early 2016	CP-1447-2

An Android Trojan dubbed Tyny.z was detected in early 2016 and was used only by the 404 criminal group. However, in August criminals started selling the Trojan under the name "Catelites Android Bot" (MarsElite Android BotNet") on the deep web. Group-IB experts predict that many other groups will also employ the malware.

The Trojan contains injects for 2,249 applications. According to its developer, he has collected these applications by parsing Google Play by keywords "bank" and "money". The Trojan scans a victim's device for an application from the list and displays a versatile window with an app icon and bank name extracted from Google Play. In addition to this universal inject, the malware includes separate injects for banks in Australia, Taiwan, Germany, New Zealand, Singapore, the UK, the US, Turkey.

Group-IB specialists detected that in Q4 2016 this Trojan compromised cards of banks in Europe, the USA, Kazakhstan, Russia, and other countries.

Malware name	Regions attacked	Detection	Notification
TrickBot	Australia, Canada, Great Britain, Germany	September 2016	CP-1471-2

A banking Trojan named Trickbot was detected in September 2016. Its configuration file contains web injects for the following banks:

- St. George
- NAB
- Westpac

- Anz
- Citibank (au)
- Canadian Imperial Bank of Commerce
- Commerzbank
- Sparkasse
- UK banks
- Also, it uses a regular expression to search for the directory “onlineserv/CM”, which is a solution named Bottomline Business Banking that is used as online banking in various banks.

It’s worth reiterating that Trickbot uses the same encryption method as that that had been used by the notorious Dyre hacker group.

Malware name	Regions attacked	Detection	Notification
Quant loader	All countries except the CIS	September 2016	CP-1484

In September 2016 Group-IB specialists detected an announcement about the sale of a new loader/ dropper dubbed Quant Loader PRO. This Trojan is designed to download and run addition malicious files on infected machines bypassing antivirus systems. The program is written in C++ and operates on all Windows OS systems. The loader has the functionality to bypass Windows Firewall, and escalate privileges to the “highestAvailable» level. Its developer is the author of other infamous malicious programs: “Madness” DDoS bot and a password stealer Z*Stealer.

The loader does not use web injects, aggressive methods of privilege escalation or exploits, which decreases the risk of its detection. To provide malware survivability in the system, the loader sets NTFS permissions on a file, folder and keys of the registry, which significantly complicates its removal manually or using programs.

Bot ID	Version	IP address	Country	Registrated	Sync	Banned to	Loads	Total
94207904	last	109.226.227.225	[RU] Russian Federation	05.08.16 10:55:57	10.08.16 01:09:23	-	-	-
84741876	last	193.34.94.71	[UA] Ukraine	05.08.16 10:55:57	10.08.16 15:57:49	-	-	-
28978904	last	176.107.241.56	[RU] Russian Federation	05.08.16 10:55:58	10.08.16 15:57:31	-	-	-
23785417	last	177.19.175.92	[BR] Brazil	05.08.16 10:56:06	10.08.16 15:58:02	-	-	-
36224489	last	89.109.238.79	[RU] Russian Federation	05.08.16 10:56:13	10.08.16 15:57:42	-	-	-
35409188	last	80.68.2.59	[RU] Russian Federation	05.08.16 10:56:14	10.08.16 15:57:14	-	-	-
60284098	last	82.207.76.142	[UA] Ukraine	05.08.16 10:56:17	10.08.16 15:57:43	-	-	-
00042492	last	92.255.166.84	[RU] Russian Federation	05.08.16 10:56:18	10.08.16 09:38:10	-	-	-
65436878	last	85.91.96.6	[RU] Russian Federation	05.08.16 10:56:19	05.08.16 15:56:05	-	-	-
80670844	last	178.248.85.53	[RU] Russian Federation	05.08.16 10:56:20	10.08.16 15:57:16	-	-	-
64764882	last	193.106.147.98	[UA] Ukraine	05.08.16 10:56:21	10.08.16 15:57:55	-	-	-
33548284	last	178.150.237.199	[UA] Ukraine	05.08.16 10:56:22	06.08.16 18:22:17	-	-	-
72481122	last	77.37.234.85	[RU] Russian Federation	05.08.16 10:56:22	10.08.16 15:57:11	-	-	-
42428944	last	178.35.149.142	[RU] Russian Federation	05.08.16 10:56:24	10.08.16 07:12:30	-	-	-
84514847	last	177.92.21.74	[BR] Brazil	05.08.16 10:56:24	09.08.16 17:31:45	-	-	-
10148881	last	5.19.168.4	[RU] Russian Federation	05.08.16 10:56:26	07.08.16 18:08:48	-	-	-
46460983	last	31.42.37.148	[RU] Russian Federation	05.08.16 10:56:27	05.08.16 14:39:37	-	-	-
74384540	last	109.251.117.68	[UA] Ukraine	05.08.16 10:56:29	09.08.16 07:48:14	-	-	-
44994319	last	195.234.213.14	[UA] Ukraine	05.08.16 10:56:30	10.08.16 15:57:15	-	-	-
84903564	last	92.42.160.203	[RU] Russian Federation	05.08.16 10:56:31	10.08.16 15:57:44	-	-	-
92304283	last	177.32.194.161	[BR] Brazil	05.08.16 10:56:32	10.08.16 15:57:41	-	-	-

Quant Loader PRO control panel

Malware name	Regions attacked	Detection	Notification
Panda Banker	All countries except the CIS	February 2016	CP-1490

Researchers originally discovered the Panda Banker malware in February, 2016. At the time, the Trojan was distributed via both targeted email campaigns and exploit kits (EKs). However, we had never observed this program available for purchase on deep web hacking forums.

On October 30 this banking Trojan appeared on the underground resource club2crd.cc. However, it was further determined that he was a fraudster, who was not related with this program. The Trojan developer hiding under the name "alkeeper" was detected on the underground resource "exploit.in", where he is selling Panda Banker via private messages on the forum.

The Trojan has the following functionality (including a grabber module and a BackSocks module):

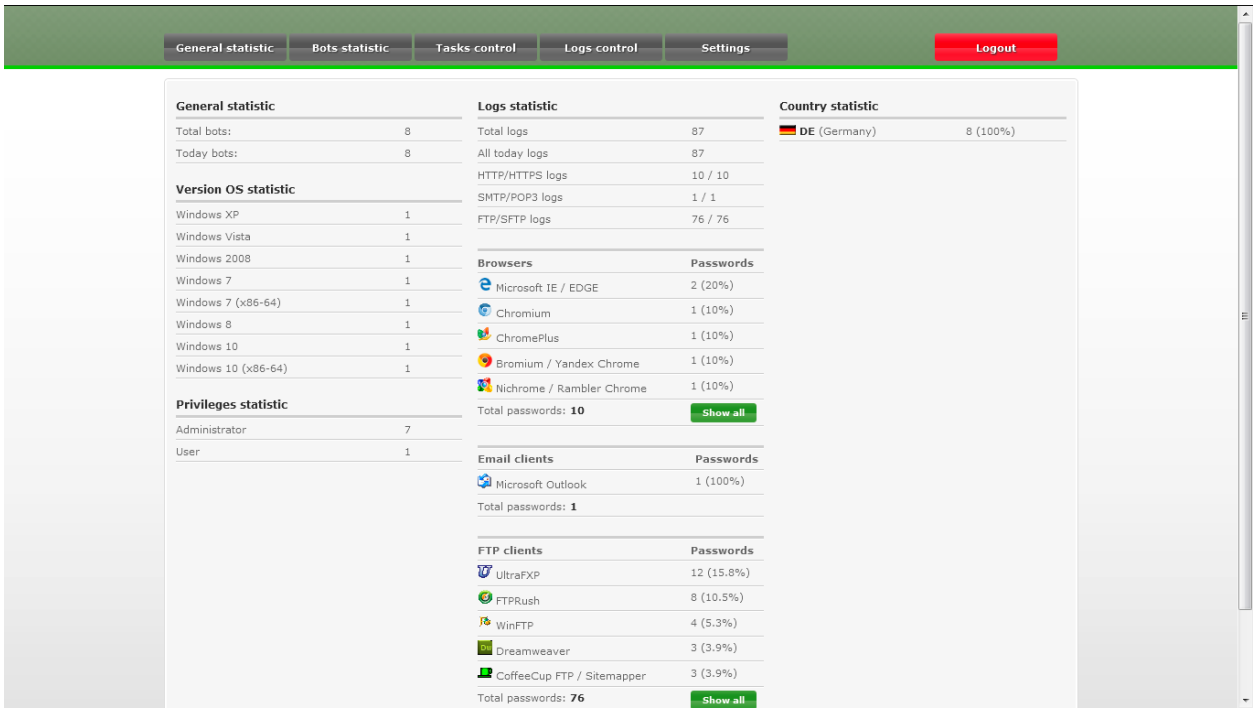
- Supports web injects (similar to those used in the Zeus banking Trojan)
- Obtains all automatically saved passwords:
- Web browsers: Internet Explorer, Mozilla Firefox, Google Chrome, Opera New
- FTP clients: FileZilla, Total Commander, Cute FTP, FireFTP (Firefox plugin), WinSCP
- Mail clients: Outlook, Windows Mail/Windows Live Mail, Mozilla Thunderbird
- Retrieves Cookies from browsers (with capability to delete them on the infected machine)
- Obtains user's certificates stored in the My store
- Receives FlashPlayer .SOL files
- Logs POST and GET requests
- Takes screenshots of browsers
- A separate plugin named backsocks designed to install socks/proxy on the infected device
- A plugin to perform covert VNC connection (operates on Windows 10)

The Trojan has built-in plugin functionality – supporting.dll modules with different capabilities, which are executed in a separate process. The above-mentioned grabber and backsocks modules are responsible for information collection and creation of socks/proxy on the infected machine respectively. Connections between bots and the control panel are encrypted using AES-128 encryption with a one-time session key generated each time a connection to the control panel is performed. That said, the session key is encrypted using a public key RSA-2048.

The fact that Panda Banker is 'officially' sold on the underground forum exploit.in means that it is not a private Trojan and can be widely used by other criminal groups. Panda Banker developers will continue improving its product to support its malicious activity on advanced highly-protected systems.

Malware name	Regions attacked	Detection	Notification
Snatch	All countries except the CIS	November 2016	CP-1498

An announcement about a new malicious program dubbed SNATCH available for sale was detected on underground forums. The program has the functionality to grab credentials from web browsers, mail and FTP clients, as well as to automatically download and run PE files. It's worth noting that this malware has positive reviews from popular members of underground forums. That said, its price is relatively low – 300 US dollars, which can lead to its wide distribution among cybercriminals.



SNATCH control panel

Malware name	Regions attacked	Detection	Notification
HVNC33	All countries except the CIS	November 2016	CP-1502

Group-IB specialists detected announcements about a new Trojan dubbed Hidden VNC33 available for purchase on underground resources. The Trojan enables the criminal to perform covert remote control of Windows-based computers from XP to Windows 10 (x32/x64).

The Trojan is written in C. It has the following functions:

- The Trojan performs actions in a parallel session that will not affect the user's session - the victim will not notice manipulations in the browser.
- The Trojan clones a browser profile and operates in the context of this account.
- Provision of the survivability in the system.
- The malware operates in Chrome, Firefox, Internet Explorer browsers.
- The Trojan is delivered as exe and dll files.

An experienced user of an underground forum checked the Trojan's workability. According to analysis, the Trojan is capable of bypassing COMODO and ESET SS antiviruses, but can be detected by the COMODO Automated Analysis System ("sandbox"). Also, the user states that HVNC33 operates correctly in Chrome and Firefox.

This malware can be used by cybercriminals to perform targeted attacks and compromise critical data.

Also, in Q4 researchers observed activity of the following banking Trojans:

Name	Detection	Countries attacked
Qadars	2013	Canada

		UK USA Italy Australia

Examples of attacked banks:

Libro Credit Union	Santander	TSB
HSBC	Metrobank (UK)	St. James's Place Bank
TD bank	Iombank	Commbank
USAA bank	Virgilio	BMO
Tangerine	Barclays	Desjardins
ING (it)	Citigroup	Tescobank
Halifax	Wellsfargo	Bankofscotlan
CIBC	53.com	

Name	Detection	Countries attacked
Gootkit	2014	UK Germany Canada France Netherlands Italy Sweden Spain

Examples of attacked banks:

snsbank.nl	fidor.de	crediteurope.nl
bankofscotland.co.uk	rabobank.nl	mbank.pl
ulsterbankanytimebanking.c	rbsdigital.com	dkb.de
o.uk	bmo.com	donner-reuschel.de
dkb.de	onvista-bank.de	regiobank.nl
sjpbank.co.uk	payangocard.de	sfr.fr
unicredit.it	nwolb.com	banquepopulaire.fr
credit-agricole.fr	cibc.com	bankia.es
citi.eu	abanquepro.bnpparibas	lcl.fr
barclays.co.uk	lloydsbank.co.uk	gilissen.nl
ubibanca.com	wellsfargo.com	berliner-bank.de
ing.nl	insidecard.de	atbank.nl
pcfinancial.ca	seb.se	iombank.com
syzgroup.com	ingbank.pl	postbank.de
fineco.it	td.com	mijn-icsbusiness.nl
firstdirect.com	deutsche-bank.de	commerzbank.de
ybonline.co.uk	moj.raiffeisenpolbank	hsbc.co.uk
tescobank.com	santander.co.uk	knab.nl
tangerine.ca	bbva.es	labanquepostale
dundeecapitalmarkets.com	alex.nl	smile.co.uk
scotiabank.com	procreditbank.de	kunde.comdirect.de
bnc.ca	bancamarche.it	co-operativebank.co.uk

cbonline.co.uk
desjardins.com
bankcardservices.co.uk
chase
halifax-online.co.uk
shaw.ca
cristalcard.de
yammer.com
metrobankonline.co.uk
lacaixa.es
nrwbank.de
tsb.co.uk
comdirect.de
norisbank.de
santanderbank.de
targobank.de
bmo.com
icscards.nl
nationwide.co.uk

Name	Detection	Countries attacked
Dridex	2014	USA UK France Australia Spain Romania

Examples of attacked banks:

bankofamerica
citibank
bbva
bmo
santander
svbconnect
whitneybank
tiaa
firstbank
americafirst
columbiabank
busey
jpmorgan
northerntrust
suntrust
pncbank
firstcitizens
hancockbank
lakelandbank
barclays
societegenerale
lcl
labanquepostale
bnpparibas
bancopopular
credit agricole
caisse-epargne
ecobank
humebank
lloydsbank
halifax
bankofscotland
ulster
danskebank (uk)
tsb
HSBC
Nationwide
pnbank
westpac
wellsfargo
chase
danske (uk)
RBS
tdbank
raiffeisen (ro)
fidelity
adelaidebank
boq
australianmilitarybank
kiwibank
NAB
suncorpbank
tmbank
Warwick Credit Union
stgeorge
usbank

Name	Detection	Countries attacked
Qbot	2009	USA Netherlands Canada

Examples of attacked banks:

citizensbankmoneymanagerg
ps.com
fundsxpress.com
firsttennessee.com
frostbank.com
suntrust.com
scotiabank.com
bankofamerica.com
usbank.com
firstcitizensonline.com
pncbank.com
53.com

goldleafach.com
ibanking-services.com
compassbank.com
wellsfargo.com
tdbank.com
mandtbank.com
firstmeritib.com
easterntreasuryconnect.com
citigroup.com
huntington.com
websterbank.com
jpmorgan.com
abnamro.nl
ebanking-services.com
svbconnect.com
capitalonebank.com

Name	Detection	Countries attacked
Tinba	2012	Australia Netherlands USA Germany Austria Italy Spain New Zealand Japan

Examples of attacked banks:

Commbank
Deutsche bank
snsbank.nl
Suntrust
wherewebank.com
somb.com.au
tsw.com.au
anz.co.nz
banksa.com.au
firstcalgary.com
sparkasse.at
ezcardinfo.com
tdbank.com
barclays.co.uk
ingdirect.com.au
ing.nl
ubank.com.au
resourcescu.com.au
westpac.co.nz
stgeorge.com.au
noventis.ca
fineco.it
bankvic.com.au
volksbank.de
hald-nor.on.ca
tangerine.ca
maitlandmutual.com.au
bankwest.com.au
desjardins.com
bankofamerica.com
scotiabank.com
cua.com.au
usbank.com
bnc.ca
openbank.es
asbbank.co.nz
lloydsbank.co.uk
nordea.fi
regiobank.nl
montepio.pt
53.com
bankia.es
beaubear.ca
asnbank.nl
berliner-bank.de
fiducia.de
membersequitybank.com.au
vub.sk
customscu.com.au
mecu.com.au
flessabank.de
postbank.de
commerzbank.de
postfinance.ch
divisioneconsumer.it
hsbccreditcard.com
bankofmelbourne.com.au
qpcu.org.au
suncorpbank.com.au
jpmorgan.com
usaa.com
hawaiiusafcu.com
bendigobank.com.au
abnamro.nl
stcu.org
anz.com
sparda.de
scottrade.com
ampbanking.com
bawagpsk.com
desjardins.com
cartasi.it
creditunionsa.com.au
halifax-online.co.uk
bbva.es
sparkasse.de
westpac.com.au
memberone.ca
boq.com.au
gruposantander.es
lacaixa.es
mebank.com.au
neteller.com
reviewmyaccount.com

financial.c
implicity.ca
bbva.esdesconexion
bccu.com.au
bbt.com
agosweb.it
shinkin-ib.jp
optionsxpress.com.au
tsb.co.uk
qantascu.com.au
bancopopular.pt
entegra.ca
cardmemberservices.net
cairnspenny.com.au
comdirect.de
norisbank.de
bmo.com
targobank.de
cardcenterdirect.com
bcu.com.au

Name	Detection	Countries attacked
Zeus	2007	Italy Spain UK Russia Australia Canada Germany UAE Bulgaria Turkey France

Examples of attacked banks:

Toronto Municipal Employees' Credit Union
ProCredit Bank
DAB Bank
Alliance & Leicester
Sabadell bank
UNOE BANK S.A.
First Calgary Financial
SEC Servizi
Banco Mediolanum
Банк УРАЛСИБ
BANCA INTESA
Barclays
Caixa
Valley First
Noventis Credit Union
OMISTA Credit Union
BANCO SABADELL
Lloyds Bank
RBKmoney
HSBC Bank
Citizens Bank Online
Chase Bank
FUNDACIÓN CAJARIOJA-BANKIA
Yorkshire Bank
Banco Santander
Laboral Kutxa
Hald-Nor Community Credit Union
Tangerine Bank
RBC Royal Bank
BOA
SunTrust Bank
Scotiabank
U.S. Bancorp
The National Bank of Canada
Openbank (es)
Royal Bank of Scotland
Wells Fargo
Santander
National Westminster Bank
Mount Lehman Credit Union
Canadian Imperial Bank of Commerce
Prospera Credit Union
Kutxabank
Northern Savings Credit Union
TD bank
Qui UBI
CajaCanarias
Reddy Kilowatt Credit Union
Citibank
Banco Pastor
Fifth Third Bank
Allied Irish Banks
Vancouver City Savings Credit Union
Türkiye İş Bankası
Banque Populaire
Poste Italiane
Beaubear Credit Union
TD Canada Trust
Citibank (com, ae)
iwbank
caixa
hsbc
smile.co.uk
webmoney.ru
provincialemployees.com
co-operativebank.co.uk
popso.it
cajabadajoz.es
cajadeavila.es

anz.com
cbonline.co.uk
cajamurcia.es
barclays.com
osmp.ru
amazon.com
caissepopclare.com
halifax-online.co.uk
bancoherrero.com
gbw2.it
cajamadrid.es
ipgold.ru
rupay.com
gruppocarige.it
hscunl.ca
memberone.ca
gruposantander.es
caixasabadell.net
bbvanetoffice.com
caixatarragona.es
lloydstsb.com
caixagirona.es
implicity.ca
first-direct.com
ccm.es
bancopopular.es
cajacirculo.es
unicaja.es
tandia.com
caja-granada.es
entegra.ca
norisbank.de
bmo.com

Name	Detection	Countries attacked
ZeusVM (KINS)	2013	UK USA Australia Italy Canada Spain Germany France

Examples of attacked banks:

procreditbank.bg
dab-bank.com
alliance-leicester.co.uk
gemvisa.com.au
bgnetplus.com
uno-e.com
elmonte.es
cardsonline-consumer.com
banksa.com.au
secservizi.it
ezcardinfo.com
mybwbcard.ca
bankofscotland.co.uk
fibancmediolanum.es
gecreditline.com.au
bancajaproximaempresas.com
mtb.com
citibank.com.au
manulifebank.com
bancaintesa.it
fdecs.com
tdbank.com
citi.eu
rabo.com.au
accessmycardonline.com
firstbankcard.com
bancorpsouthonline.com
barclays.co.uk
ingdirect.com.au
fiacardservices.com
cajasoldirecto.es
pcfinancial.ca
stgeorge.com.au
americanexpress.com
discover.com
bankvic.com.au
sabadellatlantico.com
hbs.net.au
adelaidebank.com.au
lloydstsb.co.uk
hsbc.com
citizensbankonline.com
chase.com
cajarioja.es
caixalaietana.es
ybonline.co.uk
newcastlepermanent.com.au
commbank.com.au
juniper.com
banesto.es
cajalaboral.com
barclaycardus.com
tdcardservices.com
laurent.ca
tescobank.com
bankwest.com.au
royalbank.com
suntrust.com
scotiabank.com
cua.com.au
bankofamerica.com
usbank.com
banksyd.com.au
bnc.ca
openbank.es
hsbc.com.au
rbsdigital.com
nab.com.au

banif.es
nwolb.com
tmbank.com.au
nationalcity.com
cibc.com
b-e.com.au
lloydsbank.co.uk
cajavital.es
wellsfargo.com
colesmastercard.com.au
atbonline.com
netteller.com.au
imb.com.au
amp.com
quiubi.it
td.com
pcmastercard.ca
cajaen.es
wamu.com
mlc.com.au
santander.co.uk
e-gold.com
cajacanarias.es
mycardstatement.com
citibank.de
regions.com
isideonline.it
bancopastor.es
gotomycard.com
peopleschoicecu.com.au
bochk.com
defencebank.com.au
cajamadridempresas.es
mtnwestbank.com
clavenet.net
pnc.com
macquarie.com.au
53.com
aib.ie
onlineaccess.ca
vancity.com
isbank.com.tr
ctfs.com
banquepopulaire.fr
poste.it
tdcanadatrust.com
associatedbank.com
buyersedge.com.au
onlinecreditcenter6.com
cucardsonline.com
citibank.com
iwbank.it
caixaontinyent.es
firstnational.com
myvisaaccount.com
hsbc.co.uk
myer.com.au
chasecanada.ca
hsbccreditcard.com
cardservicesdirect.com.au
citibank.ae
smile.co.uk
ingdirect.ca
suncorpbank.com.au
webmoney.ru
bcs.ru
co-operativebank.co.uk
popso.it
hawaiiusafcu.com
cajadeavila.es
cajabadajoz.es
capitalone.com
bendigobank.com.au
memberdirect.net
yandex.ru
usaa.com
anz.com
cbonline.co.uk
ptsbank.com
greater.com.au
cajamurcia.es
hsbc.ca
onlineaccounts.org
barclays.com
desjardins.com
osmp.ru
statefarm.com
halifax-online.co.uk
nationet.com
bancoherrero.com
gbw2.it
citi.com
cajamadrid.es
gruppocarige.it
westpac.com.au
boq.com.au
gruposantander.es
bbvanetoffice.com
caixasabadell.net
alterna.ca
comodo.com
mebank.com.au
caixatarragona.es
lloydstsb.com
dcbank.com
metrocreditu.com
caixagirona.es
first-direct.com
bancopopular.es
cajacirculo.es
unicaja.es
gemoney.com.au
caja-granada.es
tsb.co.uk
cardmemberservices.net
bankmecu.com.au
norisbank.de
bmo.com
investec.com.au
cardcenterdirect.com

Name	Detection	Countries attacked
Vawtrak	2013	Canada UK Italy USA

		Germany

Examples of attacked banks:

Libro Credit Union
Lloydsbank
TD bank
Unionbank
Poste
Allianzbank
USAA bank
Ulsterbank
Citibank
CIBC
Santander
Barclays
Schwab
Wellsfargo
53.com
TSB
Credem
Jpmorgan
BMO
HSBC
Deutsche bank

Name	Detection	Countries attacked
ISFB (Gozi)	2013	Italy

Examples of attacked banks:

CartaSi SpA
Banca Intesa Sanpaolo

Name	Detection	Countries attacked
Atmos	2015	Spain Canada France UK Portugal

Examples of attacked banks:

cajamadridempresas.es
tangerine.ca
labanquepostale.fr
halifax-online.co.uk
desjardins.com
royalbank.com
montepio.pt
activobank7.pt
bancobest.pt
banquepopulaire.fr
rbsdigital.com
bpinetempresas.pt
cibc.com
cic.fr
lloydsbank.co.uk
cajavital.es
wellsfargo.com
lcl.fr
deutsche-bank.pt
td.com
barclays.co.uk
grupobanif.pt
santander.co.uk
cajaespana.net
caixapenedes.com
cajacanarias.es
ing.nl
chasecanada.ca
bancopopular.pt
tsb.co.uk
barclays.pt
cgd.pt
bmo.com
caixalaietana.es
novacaixagalicia.es
lloydsbankinternational.es
finibanco.pt
nationwide.co.uk

Name	Detection	Countries attacked
Kronos	2014	Canada Brazil

		Germany

Examples of attacked banks:

tangerine.ca
itau.com.br
norisbank.de
scotiabank.com
royalbank.com
postbank.de

Name	Detection	Countries attacked
Ramnit	2011	Canada Australia UK USA

Examples of attacked banks:

hald-nor.on.ca
wherewebank.com
tangerine.ca
caissepopclare.com
accdesjardins.com
royalbank.com
scotiabank.com
bnc.ca
banksa.com.au
firstcalgary.com
gffg.com
hscunl.ca
vancity.com
solutions.c
nab.com.au
westpac.com.au
memberone.ca
mtlehman.com
cibc.com
beaubear.ca
prospera.ca
pcmastercard.ca

Attacks on ATM and POS terminals

- ATMs both in Russia and worldwide are targeted by the Cobalt hacker group. Their attacks are aimed at infecting ATM control systems. When accessing them, perpetrators send a command to make the cash machine dispense money. Detailed information is available in Notifications CP-1438-4, CP-1438-5, CP-1438-6, CP-1438-7, CP-1438-8.
- In November 2016 researchers discovered a new family of ATM malware called Alice. Based on its analysis, Alice appears to have been around since 2014. The perpetrator needs to physically access the ATM in order to empty its dispenser using the malware. Alice runs on any vendor's hardware configured to use the Microsoft Extended Financial Services middleware (XFS).
- A specialized tool designed for thefts from ATMs ("BlackBox") threatens cash machines. Detailed information on this threat is available in Notification CP-1492. In 2016 over 20 thefts from ATMs using this equipment were recorded.
- POS terminals are also under threat of attacks using specialized POS Trojans. During the reporting period Group-IB specialists did not detect announcements about sales of new Trojans, however, our previous reports informed about a number of active programs, such as Cherry Picker,

ModPOS, GamaPOS, ProjectHook, and others. These malicious programs are designed to collect Track1 + Track2 card dumps.

Data leakage

During the reporting period, the largest leak in the financial sector was data breach in Tesco bank. On November 7, 2016 the bank reported the incident, which resulted in the loss of £2.5m fraudulently withdrawn from 20,000 accounts, with suspicious activity being tracked across 40,000 accounts. After the hack Tesco Bank restricted all online transactions of current accounts.

Other major data breaches:

- GeekedIn

A tech recruitment project GeekedIn that scraped user data from GitHub was reported to have inadvertently leaked it online through a misconfigured MongoDB database, where information was stored. The analysis of the data dump revealed the presence of more than 8.5 million GitHub profiles, including names, email addresses, locations and other data. The data gathered by the service is public and does not include any sensitive information. However, the archive includes over one million of valid email addresses of developers, who use GitHub, which the recruitment project planned to monetize in the future.

- Ethereum Project

On December 19 administrators of the blockchain-based Ethereum Project released a statement announcing a data breach of the platform's community forum ethereum.org that had been performed by an unidentified criminal. The leaked database held information from a backup taken in April earlier this year. It contained information on 16,500 users, including usernames, IP addresses, email addresses, profile data, messages (both public and private), as well as hashed passwords.

An unknown attacker employed social engineering techniques to access a mobile phone number linked to several accounts, one of which had access to an old database backup from the ethereum.org forum.

- Yahoo!

On December 14, 2016 Yahoo! announced another huge security breach that happened in August 2013. The peculiarity of this attack is the amount of users affected: Yahoo says that an "unauthorized third party" stole user data from more than one billion accounts.

- MEGA

On November 17, 2016 it was reported that a group of hackers calling themselves the "Amn3s1a Team" had succeeded in hacking parts of file sharing site MEGA. Login credentials providing administrator access as well as source code fragment were published online.

- Friend Finder Networks

In October 2016 the company behind adult dating site AdultFriendFinder was hit with a massive hack — exposing more than 412 million user accounts, which is believed to be one of the largest data breaches in internet history. Exposed user data includes email addresses, passwords, dates of last visits, browser information, IP addresses and site membership status across several websites. Passwords were stored by Friend Finder Networks either in plain visible format or SHA1 hashed.

Threats to the Financial Sector in Russia

Targeted attacks

APT name	Regions attacked	Related notifications	Operation start
Targeted attacks on banks using the Cobalt Strike software	Banks worldwide	CP-1438-4 CP-1438-5 CP-1438-6 CP-1438-7 CP-1438-8	June 2016

In Q4 2016 new attacks of the Cobalt group and related indicators of compromise were detected. Targeted attacks were performed acting as Diebold and Wincor Nixdorf companies (ATM manufacturers), and the Center of Financial Technologies, a provider of solutions for the financial market of Russia and the CIS. Emails contained a malicious RTF document with an exploit for CVE-2015-1641.

Group-IB specialists also determined that the group modified the malware to complicate its detection:

- RTF objects were modified to purportedly avoid detection by YARA rules. They were adjusted in a manner that could not affect their workability, for example, developers added symbols to the names of objects.
- Loaders now have PE structure corrupted on purpose, which significantly complicates file analysis. The current payload does not contain a string beacon.dll as the "original file name" in the PE header.

In September-October 2016 the group attacked banks in Armenia, Azerbaijan, Belorussia, Hungary, Russia, and in December attacks on banks in Russia, Bulgaria, Georgia, Turkey, and Tunisia were detected.

APT name	Regions attacked	Related notifications	Operation start
MoneyTaker	Russia	CP-1500	August 2016

In late November a new criminal group using a new type of targeted attack was identified. Hackers used Moneytaker malware to furtively replace data in payment orders in a free application called Automated Working Station of the Central Bank Client (AWS CBC). Moneytaker has several modules: the core module, a module for automated data replacement, a module for hiding the malware, and a module for operation with temporary files. The attackers replace legitimate payment orders in AWS CBC with their own so that money would be sent to accounts they control instead of the legitimate recipient. The legitimate user receives a system response as if payment details were not changed and does not notice manipulations, which provides a criminal with additional time.

In addition to the above-mentioned malware, the criminals used various remote control tools, the Mimikatz program, Metasploit modules, as well as data grabbers and a keylogger.

At the time of this report, these attacks have targeted only Russian banks. However, Group-IB specialists note that the criminals have advanced technical skills to modify their malware for attacks on other systems and are expected refocus on foreign banks in the future.

Banking Trojans for PC and Android

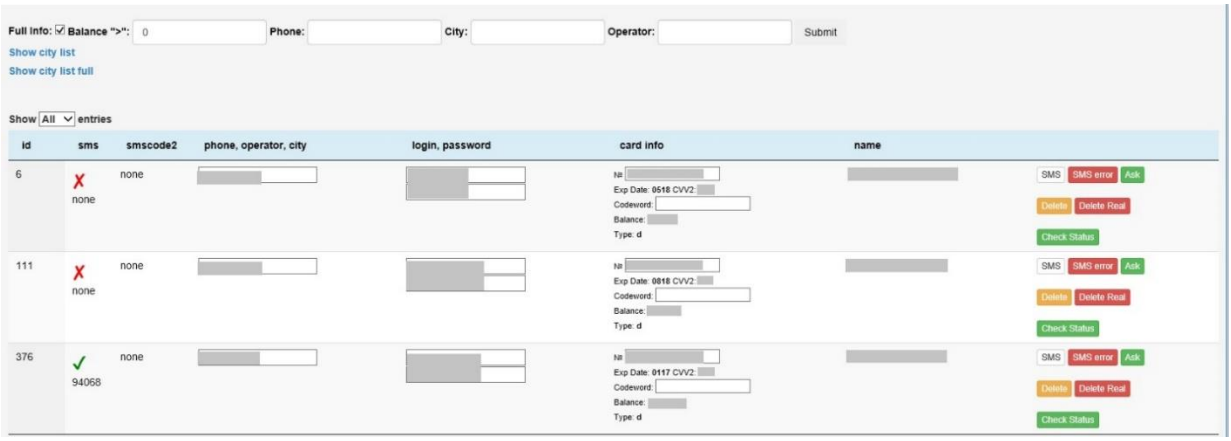
Malware name	Detection	Notification	Regions attacked
Buhtrap	2014	CP-1509	Russia

In December 2016, Group-IB specialists detected new version of Buhtrap malware with module for ATS (automatic transfer system) for «1C» system (1C is popular software for accountants in Russia). ATS allows attackers to substitute details in payment details, thus attackers will obtain transfer. This threat is actual for law entities, which use «1C».

APT name	Regions attacked	Related notifications	Operation start
ProxyAdder	2012	CG-1385-2	Russia

In Q4 2016 Group-IB specialists observed activity of the Proxy group attacking Russian banks. Researchers identified additional information about Proxy:

- Criminals used a malicious file of the Buhtrap group as a loader to infect target machines ProxyAdder. It's worth reminding that in February 2016 source code of the Buhtrap malware was published online, which led to its wide use by other groups.
- Their malicious files are signed with certificates (code signing certificate) issued to fake companies.
- In addition to the banking malware, the criminals also use Ransomware. They were detected to be using Globe (or Globe2) ransomware virus (aka Purge).



ProxyAdder control panel

Malware name	Regions attacked	Detection	Notification
Tiny.z (Catelites Android Bot)	All countries	Early 2016	CP-1447-2

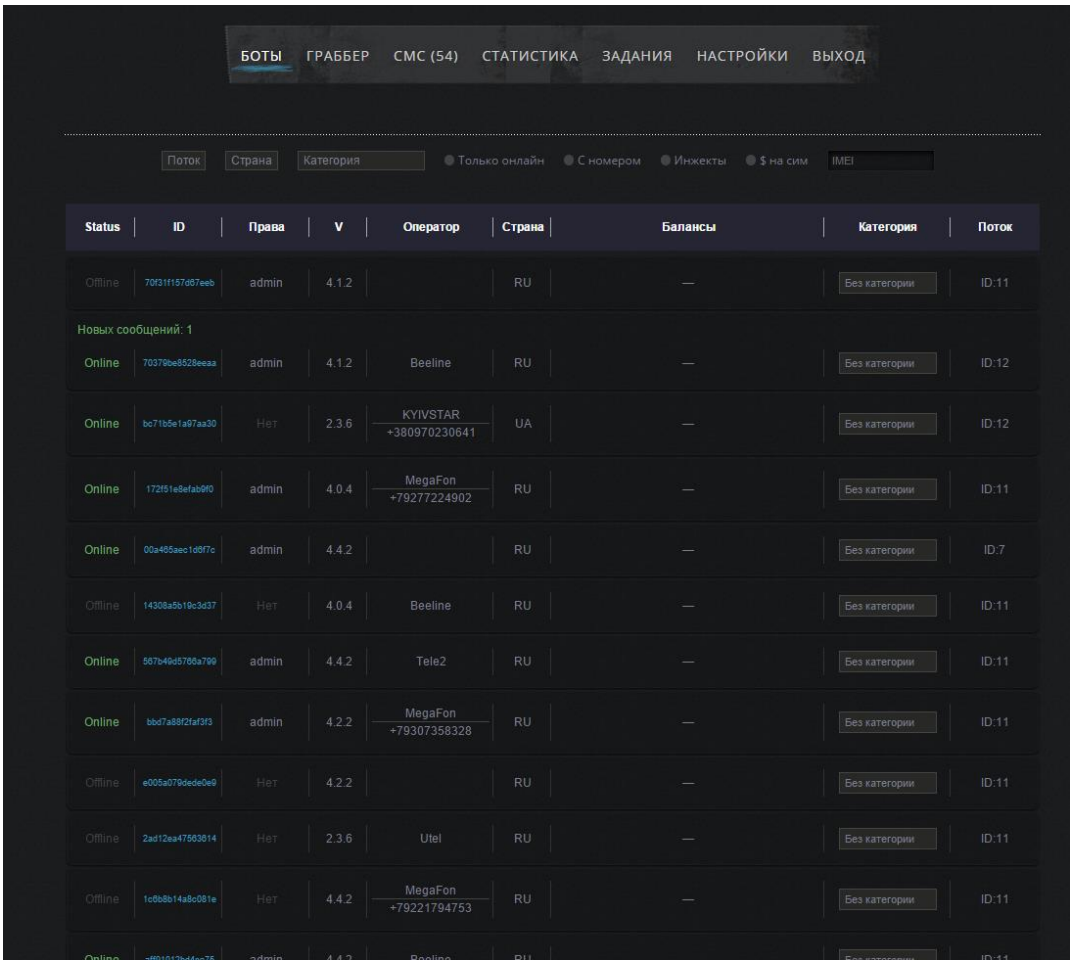
An Android Trojan dubbed Tyny.z was detected in early 2016 and was used only by the 404 criminal group. However, in August criminals started selling the Trojan under the name "Catelites Android Bot" (MarsElite Android BotNet") on the deep web. Group-IB experts predict that many other groups will also use the malware.

The Trojan contains injects for 2,249 applications. According to its developer, he collected these applications by parsing Google Play by keywords “bank” and “money”. The Trojan scans a victim’s device for an applications from the list and displays a versatile window with an app icon and bank name extracted from Google Play. In addition to this universal inject, the malware includes separate injects for banks in Australia, Taiwan, Germany, New Zealand, Singapore, the UK, the US, Turkey.

Due to Bot-Trek Intelligence system, Group-IB specialists detected that in Q4 2016 this Trojan compromised cards of banks in Europe, the USA, Kazakhstan, Russia, and other countries.

Malware name	Regions attacked	Detection
Agent.BID	Russia	August 2015

Agent.BID is a banking Trojan targeting Android-based devices that has web inject functionality. In Q4 Group-IB specialists observed activity of a criminal group, which we dubbed Hello68, using Agent.BID. The group targets banks in the following countries: Russia, Belorussia, Ukraine, Armenia, Kazakhstan, USA, Canada, China, India, Germany, France, the UK, Australia and others.



Agent.BID control panel

Malware name	Regions attacked	Detection
Asacub	Russia	2016

In Q4 specialists observed activity of hacker groups using an Android Trojan Asacub to attack Russian banks, such as Sberbank, Alfa-Bank, Tinkoff Bank, as well as the following payments systems: QIWI Wallet, iMTCPay, MOBI.Dengi. The malware has capabilities to steal user data (such as SMS messages, bank card data, device location), display a phishing dialogue box on the top of official applications, and delete all APK files (uninstall all applications) on the device.

Malware name	Regions attacked	Detection
Grapereh	July 2016	Russia

In December 2016 researchers detected that contextual advertising in Yandex.Direct was used to distribute the “Grapereh” Andoid Trojan masked as a Sberbank online application.

The program performs the following activity:

- Requests administrator privileges on the infected device;
- Connects to the C&C server by a specified address to obtain commands to be executed and upload collected information;
- Can transfer all incoming SMS messages to the C&C server;
- Can copy bank card data by displaying a web page located at the following URL address: http://управляющий_сервер/sberbank_landing/ app/?deviceID=<значение_deviceID>. Purportedly, such web page prompts the user to enter a bank card number, card expiration date and CVC code.
- After reboot the program continues its operation.
- Hides its icon in the application list.

In the investigated incident the malware was distributed as a Sberbank online application, however, there is still a risk that criminals disguise it as applications of other banks.

Malware name	Regions attacked	Detection
Gugi/Limebot	August 2016	Russia

In Q4 2016 Gugi/Limebot attacked the following Russian banks: VTB24, Raiffeisen Bank Russia, Tinkoff Bank, Alfa-Bank, Sberbank. The Trojan is distributed via SMS spamming. To collect data the malware uses fake windows.

Attacks on ATMs

- ATMs are targeted by the Cobalt hacker group. Their attacks are aimed at infecting ATM control systems. When accessing them, perpetrators send a command to make the cash machine dispense money. Detailed information is available in Notifications CP-1438-4, CP-1438-5, CP-1438-6, CP-1438-7, CP-1438-8.
- A specialized tool designed for thefts from ATMs ("BlackBox") also threatens cash machines. Detailed information on this threat is available in Notification CP-1492. In 2016 over 20 thefts from ATMs using this equipment were recorded.

Data leakage

During the reporting period Group-IB specialists detected 8 incidents of providing/selling/searching for confidential bank data related to Russian banks on underground resources. Insiders in banks are believed to be involved in these incidents. Criminals offered the following information:

They include:

- Sales of clients' databases;
- Sales of information about bank accounts;
- A service of unblocking frozen accounts.

Threats to the Government sector

APT

APT name	Regions attacked	Operation start
Cozy Bear, APT29, CozyDuke, The Dukes	USA	November 9, 2016

On November 9, 2016, just after Donald Trump won the US presidential election, a spear phishing campaign was launched by the Cozy Bear group. Their primary targets in these coordinated and well-planned attacks appeared to have been non-governmental organizations and think tanks in the US. The hacker group used a malicious program dubbed "PowerDuke", first seen in August 2016. Researchers observed five different attack waves. Three of the attack waves contained links to deliver the malware on the victim's machine. The other two attacks contained documents with malicious macros embedded within them.

APT name	Regions attacked	Operation start
The Shadow Brokers	-	August 2016

The Shadow Brokers group that claimed to have hacked into "Equation Group", unsuccessfully tried to auction off exploits and hacking tools they were able to steal. The Shadow Brokers crew, which first emerged in August this year, is currently publishing new files from the from the purported Equation Group hack or additional information about those files. The latest release from The Shadow Brokers contained information about various software samples with their price and functionality of these programs.

APT name	Regions attacked	Operation start
KeyBoy	Tibet	August 2016

KeyBoy is a malicious program that was used to spy on members of the Tibetan Parliament over August and October 2016. To deliver malware on the victim's machine, criminals used exploits for known and patched vulnerabilities. The main infection vector were emails with malicious documents attached.

APT name	Regions attacked	Operation start
Fancy Bear, APT28, Sofacy, Pawn storm, Sednit, Strontium Tsar Team	Ukraine	2014

The Fancy Bear hacker group, which is responsible for WADA and DNC hacks, tracked Ukrainian artillery units from late 2014 through 2016. The attackers obtained remote access to a legitimate app used by Ukrainian troops to facilitate targeting. The Android app was reportedly created by Yaroslav Sherstuk, an officer of the 55th Artillery Brigade in Ukraine.

APT name	Regions attacked	Operation start
Moonlight	Middle East	2014

A hacker group dubbed Moonlight after the name of its control server, performs attacks using a popular malicious program. These cyber-espionage attacks primarily target politicians in the Middle East.

APT name	Regions attacked	Operation start
BLACKGEAR	Taiwan, Japan	2012

BLACKGEAR is a cyber-espionage campaign that is performed used theELIRKS software, originally discovered in 2012. The group is known for using blogs and microblogging services to hide the location of its actual command-and-control (C&C) servers. This allows an attacker to change the C&C server used quickly by changing the information in these posts. Another specific feature is the services the criminals chose: they used the most popular services in the target region.

Hacktivism

In Q4 2016, hacktivists conducted over 2,600 attacks on more than 3,300 various online resources. Over 1,400 attacks detected were of the "page replacement" type (Defacement) and 1,100 attacks were DDoS attacks (Denial of Service) targeting government, financial, commercial, non-governmental and non-profit organizations. Government websites suffered hacker attacks include those of Gabon, Brazil, Chile, Thailand, Colombia, Syria, Ecuador, Turkey, Japan and others.

The table below contains information on the major hacktivists' operations conducted in Q4 2016.

Operation name	Regions attacked	Operation start	Types of attacks during the operation
OpGabon	The Gabonese Republic	1.04.2013	DDoS
	Description: the operation targets online resources of Gabon. It was initiated by the Anonymous group protesting against controversial results of the Gabon's presidential election.		
OpBEAST, OpWhales, OpKillingBay	North America, Northern Europe, Southeast Asia		DDoS
	Description: OpBEAST, OpWhales and OpKillingBay operations were started by various hacker groups in order to attract public attention to animal protection issues. Initially they had targeted websites of entertainment theme parks, water parks and zoos to have further focused their attention on resources belonging to seafood suppliers and technology conglomerates which were considered to damage ecology. Currently, the hacktivists target websites of Japanese financial and government organizations, Norwegian government organizations, Icelandic seafood restaurants, and Texas government organizations (USA).		
OpISIS	ISIS, Middle East, Islamic organizations worldwide	11.08.2014	DDoS
	Description: during the OpISIS operation hackers attacked websites related to terrorism as well as religious and information Islamic websites and media resources.		
OpIcarus	North America, Northern Europe, East and Southern Africa, North Africa, Southwest Asia	03.05.2016	DDoS
	Description: during the operation hackers attacked banking and financial institutions of various countries, such as Lloyds Bank, Colombo Stock Exchange, Bermuda Monetary Authority.		

Group-IB specialists have summarized statistics of hacked websites (deface attacks), which is presented in charts below.

Chart 1 provides the breakdown of attacked resources by web servers used.

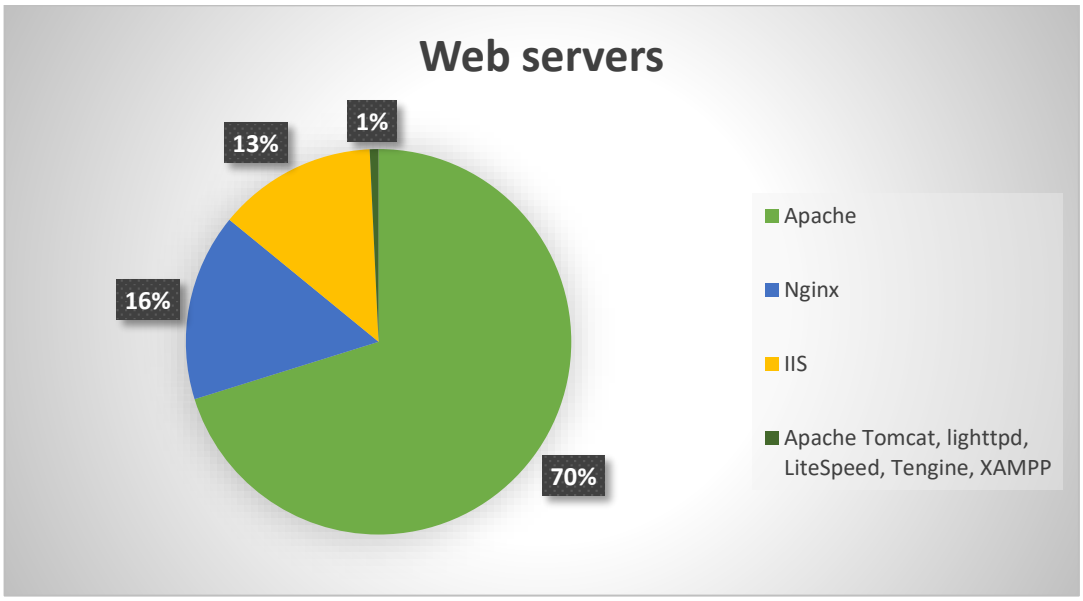


Chart 1 - Percentage of versions of web servers of attacked resources

Chart 2 provides the breakdown of attacked resources deployed using IIS web servers. As seen from the chart, the most popular versions are 6.0 and 7.5. This can be explained by the fact that each version is released as a component of a Windows operating system. For example, version 6.0 was included in Windows Server 2003, and version 7.5 was part of Windows 7 and Windows Server 2008.

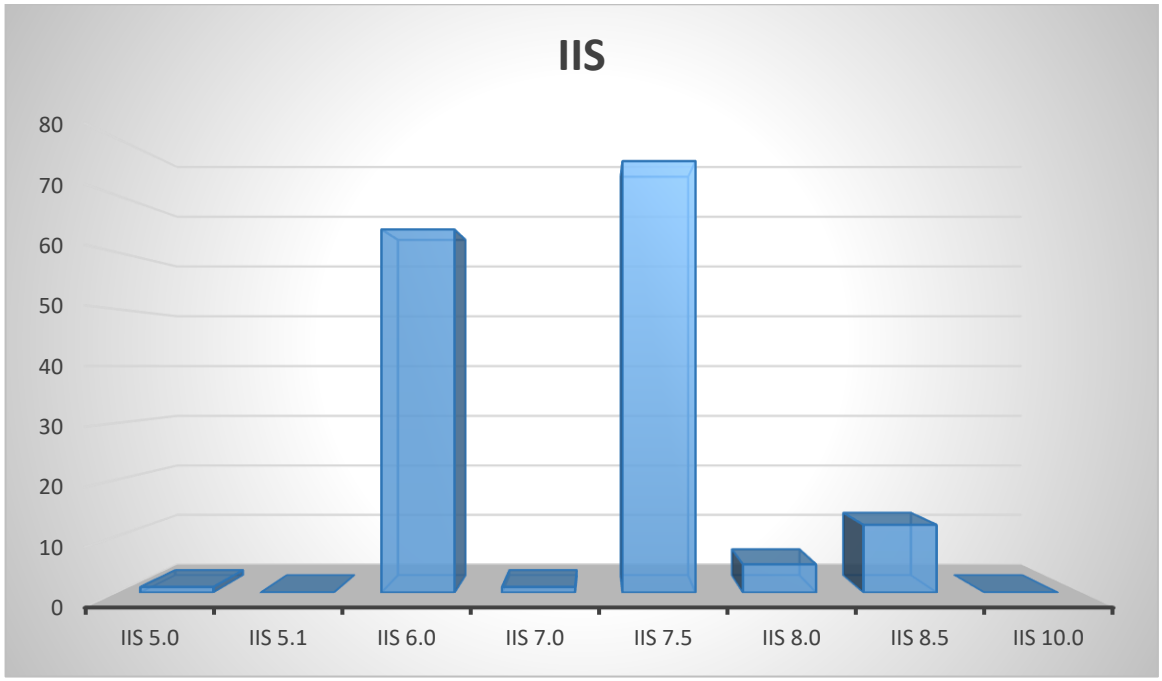


Chart 2 - The ratio of installed versions of IIS Web servers

Chart 3 provides percentage ration of the latest available stable CMS (Content management system) version and the CMS version installed on the attacked resources.

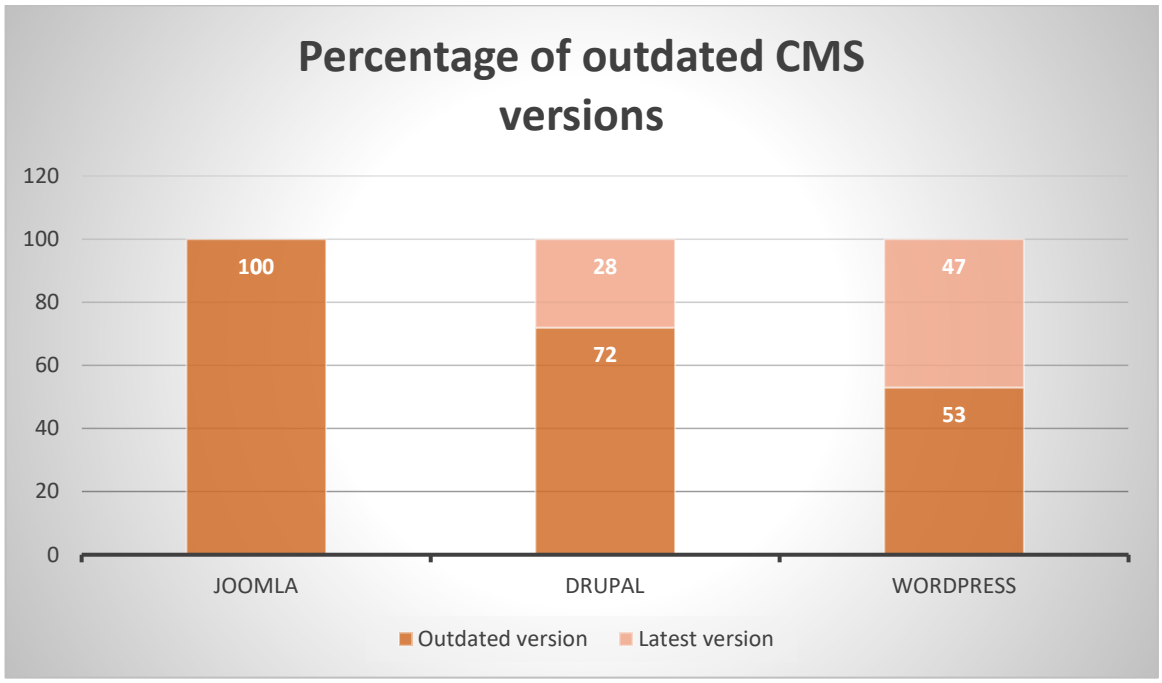


Chart 3 - Percentage of outdated and latest versions of installed CMS

These statistics clearly indicate that deploying authorized software updates in a timely manner provides protection against various attacks.

Data leakage

During the reporting period the following attacks and data breaches were detected:

- On October 23 an American hacker, who calls himself "The Jester", claimed to have hacked the website of the Russian Ministry of Foreign Affairs. He is reported to have left a message: Stop attacking Americans. The official representative of Russian foreign Ministry confirmed the hack and asserted that it was the old site that was attacked and the main website was working "in normal mode."

- Prior to the presidential elections in the US, a security vulnerability was discovered in the Donald Trump's website (donaldjtrump.com) that allowed users to publish whatever they wanted on the top of the site by adding any words to the website's URL. Example: “donaldjtrump.com/press-releases/archive/, for example: donaldjtrump.com/press-releases/archive/donald&trump&accepts&defeat”.

SCHEDULE
ABOUT
GALLERY
TRUMP PENCE
POSITIONS
STATES
GET INVOLVED
MEDIA
SHOP
CONTRIBUTE
DONALD TRUMP ACCEPTS DEFEAT
Michael Margolis
@yipe
Follow
Trump should fire his web developers.donaldjtrump.com/press-releases...
1:27 AM - 9 Nov 2016
27
43